

C2.2 | Documento de Arquitectura aprobado

SSO

Ministerio de Educación, Deporte y Cultura (MINEDEC)

CNT

MINEDEC

Versión 0.1

2026

Control del documento

Campo	Información
Documento	Documento de Arquitectura del Sistema de Autenticación Centralizado SSO
Código	
Versión	0.1
Fecha	09/10/2026
Responsable	Equipo de Desarrollo

Historial de versiones

Versión	Fecha	Responsable	Descripción del cambio
0.1	09/10/2026	Equipo de Desarrollo	Versión inicial del documento

Identificación del entregable

Campo	Información
ID del entregable	C2-50
Componente	C2
Subcomponente	Implementación del Sistema de Autenticación Centralizado SSO
Fase / etapa	Fase de Análisis y Diseño de Arquitectura
Nombre contractual del entregable	Documento de Arquitectura aprobado
Proyecto / iniciativa	Single Sign-On (SSO) y Plataforma Central de Autenticación y Autorización
Entidad / cliente	Ministerio de Educación, Deporte y Cultura (MINEDEC)
Responsable	Equipo de Desarrollo
Versión	0.1

Contenido

Control del documento 1
Historial de versiones 2
Identificación del entregable 2
Contenido 2
1. Contexto e introducción 4
1.1 Antecedentes 4
1.2 Relación con otros subcomponentes 4
2. Objetivo 4
3. Alcance 4
3.1 Dentro del alcance 4
3.2 Fuera del alcance 5
3.3 Audiencia 5
4. Insumos, dependencias y fuentes 5
5. Desarrollo específico del entregable 6
5.1 Principios de diseño 6
5.2 Situación actual (As-Is) 7
5.3 Arquitectura objetivo (To-Be) 7
5.4 Autenticación, segundo factor y sesiones 8
5.4.1 Identidad y dominios 8
5.4.2 Flujos de autenticación 9
5.4.3 Segundo factor y recuperación de contraseña 9
5.4.4 Sesiones y cierre de sesión (SLO) 9
5.5 Usuarios externos 9
5.6 Modelo de autorización RBAC + ABAC 10
5.7 Contrato de autorización 10
5.7.1 Autenticación del consumidor: POST /api/v1/oauth/token 11
5.7.2 Evaluación: POST /api/v1/authorize 11
5.7.3 Códigos HTTP y cierre ante fallas 12
5.8 Patrones de integración y paquete estándar 12
5.9 Integración perimetral: alternativas de PEP 13
5.9.1 Cabeceras X-Minedec-* y anti-suplantación 14
5.9.2 Cierre de red en los centros de datos 15
5.10 Consola de administración y publicación de aplicaciones 15
5.11 Sincronización de identidades y cuotas 16
5.12 Infraestructura en Google Cloud 17
5.12.1 Red 17
5.12.2 Cuentas de servicio 18
5.12.3 Alta disponibilidad y recuperación 19
5.13 Seguridad, auditoría y observabilidad 19
5.14 Decisiones de arquitectura 19
6. Validación, criterios de aceptación y evidencias 20
7. Conclusiones 21
8. Recomendaciones y próximos pasos 21
8.1 Decisiones pendientes 21

8.2 Próximos pasos 22
9. Referencias **22**
10. Anexos **24**
Anexo A. Glosario 24
Anexo B. Riesgos técnicos 25

1. Contexto e introducción

El Ministerio de Educación, Deporte y Cultura (MINEDEC), con la Corporación Nacional de Telecomunicaciones (CNT EP), implementa el Single Sign-On (SSO) y Plataforma Central de Autenticación y Autorización del Ministerio. Google Cloud Identity, a través del tenant institucional de Google Workspace, es el proveedor de identidad; el SSO decide qué puede hacer cada persona en cada aplicación, conforme a los Términos de Referencia [1].

Este documento es la arquitectura del Subcomponente C2.2, Implementación del Sistema de Autenticación Centralizado SSO (entregable C2-50). Describe los componentes de la plataforma central: el motor de decisión de acceso (PDP), la consola y la API de administración (PAP), el repositorio de identidades y permisos (PIP), el sincronizador de solo lectura desde Google Workspace, los patrones de integración de aplicaciones, la publicación perimetral, la infraestructura en Google Cloud y los controles de seguridad, auditoría y observabilidad.

1.1 Antecedentes

El Ministerio atiende a una de las comunidades de usuarios más grandes del Estado: cerca de 2,1 millones de estudiantes, 160.000 docentes y directivos, 10.000 funcionarios administrativos y decenas de miles de ciudadanos. Su parque tiene alrededor de 170 aplicaciones construidas en distintas épocas y tecnologías, la mayoría con tablas locales de usuarios y contraseñas [2].

En la reunión del 22 de septiembre de 2026 el MINEDEC definió que Cloud Identity es la única fuente de verdad de las identidades del SSO, que se descarta la sincronización con Active Directory, que la cédula (o un identificador único para quien no la tiene) identifica a la persona y que los roles y permisos residen en una base independiente, a medida dentro del SSO [2][3].

1.2 Relación con otros subcomponentes

- **C1.4 (Componente 1):** crea y actualiza en Google Workspace las cuentas de los estudiantes; el SSO las lee, nunca las escribe.
- **C2.3:** integra dos aplicaciones legadas con la plataforma usando el contrato de autorización y el paquete estándar que define este documento. Su diseño está en el Documento de Arquitectura C2-59 [24].

2. Objetivo

Definir la arquitectura de la plataforma central de autenticación y autorización del MINEDEC para más de 2,3 millones de identidades, con autenticación federada en Google Cloud Identity, autorización centralizada por roles y atributos, sincronización de solo lectura con Google Workspace, administración delegada desde una consola, integración estandarizada de aplicaciones y operación segura, auditable y escalable en Google Cloud.

3. Alcance

3.1 Dentro del alcance

- Configuración de Cloud Identity como proveedor de identidad: dominios, unidades organizativas, grupos, atributos extendidos, políticas de sesión, segundo factor (2SV) y recuperación de contraseña.
- Federación SAML 2.0 y OpenID Connect y el paquete estándar de integración (componente SP/RP) para las aplicaciones del Ministerio.
- Gestión de sesiones y análisis de aplicabilidad del cierre único de sesión (SLO).
- Motor de autorización (PDP), contrato de autorización REST, modelo RBAC + ABAC y catálogo de rutas.
- Consola y API de administración (PAP) para aplicaciones federadas, rutas, roles, permisos, perfiles, atributos y administradores delegados.
- Sincronizador de identidades de solo lectura desde Google Workspace y conciliación masiva.
- Integración perimetral con un punto de ejecución de políticas (PEP) y publicación automatizada de aplicaciones desde la consola.
- Infraestructura en Google Cloud definida como código, red, conectividad híbrida, seguridad, auditoría, monitoreo y alta disponibilidad.

3.2 Fuera del alcance

- La integración específica de las dos aplicaciones legadas, que corresponde a C2.3 [24].
- El aprovisionamiento de cuentas en Google Workspace, a cargo de C1.4 y de los administradores del MINEDEC.
- La gestión de dispositivos y el inicio de sesión de Windows contra Active Directory, que no cambian [2].
- La asignación de licencias de Google Workspace a usuarios externos, que el MINEDEC descartó [2].

3.3 Audiencia

Directores de TIC y administrador del contrato (visión general, decisiones y riesgos); arquitectos, desarrolladores, ingenieros de nube y DevOps de CNT; y Seguridad Informática y administradores de Google Workspace del MINEDEC (componentes, contratos, red, cuentas de servicio y controles).

4. Insumos, dependencias y fuentes

La Tabla 1 resume los insumos del cliente, las dependencias con otros entregables y las fuentes de este documento.

Tabla 1. Insumos, dependencias y fuentes de C2-50

Tipo	Elemento	Procedencia / responsable	Observación
Fuente / referencia	Términos de Referencia, Componente C2, Subcomponente 2	MINEDEC	Documento rector [1].
Fuente / referencia	Documento de Requerimientos del SSO	CNT	Versión 0.4: requerimientos RF,

			RNF, brechas (BR) y decisiones (D-xx) [2].
Insumo del cliente	Acta de la reunión del 22 de septiembre de 2026	MINEDEC / CNT	Descarte de Active Directory, Cloud Identity como fuente única y cédula como identificador [3].
Insumo del cliente	Dominios de docentes y administrativos y tenants de Workspace (D-21)	MINEDEC – Coordinación General de TIC	Pendiente. Estudiantes: estudiante.edu.ec [1].
Insumo del cliente	Cuentas de prueba por tipo de usuario en una unidad organizativa aislada (D-15)	MINEDEC – Administrador de Workspace	Pendiente. Necesarias para probar la federación, el 2SV y la sincronización.
Insumo del cliente	Accesos de lectura para la sincronización: delegación de dominio y sink de auditoría (D-20)	MINEDEC – Administrador	Pendiente. Habilita la sincronización con datos reales.
Insumo del cliente	Atributos del esquema MINEDEC_Perfil cargados en Workspace	MINEDEC / C1.4	Condicionan el modelo ABAC y la sincronización.
Insumo del cliente	Niveles de servicio: disponibilidad, RTO, RPO y concurrencia pico (D-06)	MINEDEC – Coordinación General de TIC	Pendiente. Dimensionamiento y pruebas de carga.
Insumo del cliente	Región de Google Cloud según la política de residencia de datos (D-10)	MINEDEC – Asesoría jurídica	Pendiente. Se fija antes de crear los proyectos.
Insumo del cliente	Alternativa de PEP y su costo (D-16); ubicación de las aplicaciones y conectividad híbrida (D-17)	MINEDEC – TIC e Infraestructura	Pendientes. Condicionan el patrón perimetral.
Dependencia interna	C2-49 Documento de Análisis Funcional de C2.2	CNT – equipo C2	Flujos, reglas de negocio, roles y atributos.
Dependencia interna	C1.4: aprovisionamiento de cuentas de estudiantes	CNT – equipo C1	Crea las cuentas que lee el SSO; comparte la cuota de la Directory API si usa el mismo proyecto [4].

Fuente: elaboración propia.

5. Desarrollo específico del entregable

El capítulo sigue la estructura de la plantilla para documentos de arquitectura: principios, situación actual, arquitectura objetivo y sus componentes, integraciones, infraestructura, decisiones de arquitectura y, en el capítulo 8, las brechas y decisiones pendientes.

5.1 Principios de diseño

- **Confianza cero:** ninguna aplicación ni red es confiable por defecto; cada acceso se autentica en Google y se autoriza en el SSO [11].
- **Separación de responsabilidades (modelo PEP/PDP/PAP/PIP):** quien aplica la decisión (la aplicación o el PEP) es distinto de quien decide (PDP), de quien administra las políticas (PAP) y de quien aporta los atributos (PIP) [12].
- **Google fuera del camino crítico:** la autenticación y la autorización no llaman a las APIs de Google; usan la copia sincronizada de identidades [4].
- **Solo lectura sobre Workspace:** las altas, bajas y cambios se hacen en Cloud Identity; el SSO los copia y nunca escribe en el directorio [2].
- **Cierre ante fallas (fail-close):** si el motor de autorización o sus datos no están disponibles, el acceso se deniega; nunca se concede por defecto.
- **Estándares abiertos:** OIDC (Authorization Code con PKCE S256) como protocolo principal y SAML 2.0 como alternativo [7][8][9].
- **Cero secretos en código:** credenciales, llaves y certificados en Secret Manager, sin llaves JSON de cuentas de servicio.
- **Todo como código:** la infraestructura se define en Terraform y se despliega con pipelines; no hay cambios manuales en la consola de Google Cloud.

5.2 Situación actual (As-Is)

- **Credenciales dispersas:** cada aplicación guarda usuarios y contraseñas en sus propias tablas, sin segundo factor ni visibilidad central de accesos.
- **Bajas manuales:** la salida o el traslado de un funcionario exige desactivar cuentas aplicación por aplicación, con riesgo de cuentas activas olvidadas.
- **Autorización embebida:** los roles y su alcance (institución, distrito, zona) están codificados en cada sistema, sin un catálogo común.
- **Directorio:** Google Workspace ya es el directorio de correo de las tres poblaciones; Active Directory queda fuera del SSO por decisión del MINEDEC [3].

5.3 Arquitectura objetivo (To-Be)

La Figura 1 muestra la arquitectura objetivo y la Tabla 2 describe sus componentes. Las aplicaciones autentican a los usuarios con Google Cloud Identity y consultan al SSO qué pueden hacer. El SSO corre en Google Cloud y combina la identidad sincronizada de Workspace con los roles, perfiles y atributos que administra el Ministerio.

Figura 1. Arquitectura objetivo del SSO (C2.2)

Por definir (TBD): insertar el diagrama de la página «Componentes v3» de Arquitectura_componentes_v2.drawio.

Tabla 2. Componentes de la plataforma central

Componente	Plataforma	Tecnología	Responsabilidad
Proveedor de identidad (IdP)	Google Cloud Identity / Workspace	OIDC y SAML 2.0 [5][6]	Autentica con contraseña y 2SV, aplica las políticas de sesión por unidad organizativa y emite ID Tokens y aserciones SAML.
Motor de autorización (PDP)	GKE Autopilot [13]	Node.js 22 LTS, TypeScript 5 (modo estricto), Express	Expone /api/v1/oauth/token y /api/v1/authorize, evalúa el catálogo de rutas y las reglas RBAC + ABAC

			y firma la aserción X-Minedec-Assertion.
API de administración (PAP)	GKE Autopilot	Node.js 22 LTS, TypeScript 5	Gestiona aplicaciones, rutas, credenciales, roles, permisos, perfiles, grupos lógicos, asignaciones y consultas de auditoría.
Consola web de administración	GKE Autopilot, detrás de IAP y Cloud Armor [22][23]	React 18, TypeScript, Vite	Interfaz del superadministrador y de los administradores de aplicativo.
Servicio de identidades (PIP)	GKE Autopilot	Node.js 22 LTS, TypeScript 5	Mantiene la ficha de identidad (persona, cuentas y atributos MINEDEC_Perfil) y el registro en caliente.
Repositorio de identidades y permisos	AlloyDB for PostgreSQL 16, alta disponibilidad regional [14]	PostgreSQL 16, migraciones versionadas	Copia sincronizada de identidades, catálogo de aplicaciones y rutas, reglas de autorización, cola de publicaciones y auditoría inmutable.
Caché de decisiones	Memorystore for Redis, alta disponibilidad [15]	Redis 7, TTL de 300 s	Fichas de atributos y permisos precalculados; evita consultas repetidas a AlloyDB.
Sincronizador de identidades	Cloud Run (servicio) [16]	Node.js 22 LTS, Pub/Sub, Cloud Tasks	Procesa los eventos de auditoría de Workspace, actualiza AlloyDB y purga la caché.
Conciliación masiva	Cloud Run (job) con Cloud Scheduler [25]	Node.js 22 LTS	Carga inicial y conciliación nocturna de ~2,3 millones de cuentas, con puntos de control.
Publicador y sondeador del catálogo	Cloud Run (job y servicio)	Node.js 22 LTS, Infrastructure Manager [20]	Aprovisiona el borde de cada aplicación publicada y verifica el estado real de certificados, DNS y backends.
Punto de ejecución perimetral (PEP)	Apigee X o GKE Gateway con Envoy (D-16) [17][18]	Políticas declarativas o filtro ext_authz [19]	Protege las aplicaciones del patrón 2: autentica, consulta el PDP e inyecta las cabeceras X-Minedec-*.
Paquete estándar SP/RP	Librería versionada que usa cada aplicación	OIDC, SAML 2.0 y cliente del contrato	Integra una aplicación (patrón 1) con Google y con el SSO sin desarrollos a medida.

Fuente: elaboración propia.

5.4 Autenticación, segundo factor y sesiones

5.4.1 Identidad y dominios

El correo institucional inicia la sesión; la cédula identifica a la persona. Para extranjeros o personas sin cédula se admite pasaporte o un código MINEDEC, que se reemplaza por la cédula cuando la persona la obtiene. Una persona con varias cuentas (por ejemplo, docente y administrativa) mantiene una sola identidad en el SSO [2].

El dominio determina la población: estudiante.edu.ec para estudiantes y los dominios de docentes y administrativos que confirme el MINEDEC (D-21). Las políticas de 2SV, duración de sesión y acceso se aplican por unidad organizativa [2].

Tabla 3. Poblaciones de identidad

Población	Volumen aproximado	Cuenta	Resolución de permisos
Administrativos	~10.000	Cuenta institucional (dominio por confirmar, D-21)	Roles por aplicación y alcance por dependencia, zona o distrito.
Docentes y directivos	~160.000	Cuenta institucional (dominio por confirmar, D-21)	Roles por aplicación y alcance por institución (AMIE), incluidas varias sedes.
Estudiantes	~2.106.969	estudiante.edu.ec (aprovisionada por C1.4)	Contextual, por atributos (nivel, institución); sin filas de asignación por estudiante.
Usuarios externos	~76.000 por convocatoria	Sin licencia de Workspace (D-02)	Roles y vigencia definidos por la aplicación que los atiende.

Fuente: elaboración propia.

5.4.2 Flujos de autenticación

- **OIDC con Authorization Code y PKCE S256 (principal):** la aplicación redirige a Google con el desafío PKCE, el usuario se autentica (con 2SV si su unidad organizativa lo exige) y la aplicación cambia el código por el ID Token en su backend y valida la firma RS256 con las llaves públicas de Google [5][7][8].
- **SAML 2.0 iniciado por el SP (alternativo):** la aplicación envía un AuthnRequest y valida la firma de la respuesta de Google con el certificado del IdP; se usa cuando el stack no admite OIDC de forma confiable [6][9].
- **Contenido mínimo del token:** el correo autenticado. La identificación, los roles y el alcance no viajan en la aserción: los devuelve el SSO en /api/v1/authorize [2].

5.4.3 Segundo factor y recuperación de contraseña

- 2SV obligatorio para administrativos y para cualquier cuenta con privilegios de administración; para docentes y estudiantes se aplica según la política que apruebe el MINEDEC por unidad organizativa.
- La recuperación de contraseña usa las funciones nativas de Google (correo o teléfono de recuperación, o restablecimiento por un administrador delegado).

5.4.4 Sesiones y cierre de sesión (SLO)

Google Cloud Identity no implementa el cierre único de sesión: no expone un end_session_endpoint de OIDC ni procesa LogoutRequest de SAML [2]. La arquitectura lo resuelve en tres capas:

1. **Cierre local:** la aplicación invalida su sesión y sus cookies y redirige a la página de salida institucional.
2. **Revalidación periódica:** toda decisión de autorización vence a los 300 s; vencida, la aplicación o el PEP vuelve a consultar al SSO.

3. **Revocación por suspensión:** al suspender una cuenta en Workspace, el sincronizador marca la cuenta en AlloyDB y purga la caché; el siguiente acceso se deniega, a más tardar en 300 s.

Las aplicaciones en las que aplica el cierre coordinado se definen con el administrador del contrato (D-11).

5.5 Usuarios externos

Los usuarios externos (aspirantes a becas, postulantes a concursos, representantes legales y organizaciones) no reciben licencias de Google Workspace [3]. La Tabla 4 compara los mecanismos en evaluación; la elección y su costo corresponden al MINEDEC (D-02).

Tabla 4. Mecanismos de identidad para usuarios externos

Mecanismo	Descripción	Ventajas	Consideraciones
A. Cloud Identity Free	Cuentas administradas en un dominio o unidad organizativa segregada.	Mismo IdP y mismas políticas que los usuarios internos.	Cupo de cuentas gratuitas limitado; requiere gestión de altas.
B. Identity Platform	Servicio CIAM de Google Cloud con registro propio, verificación de correo, recuperación y MFA [27].	Autoservicio y escala para convocatorias masivas.	Costo por usuario activo mensual; IdP distinto de los internos.
C. Federación con cuentas personales	El ciudadano entra con una cuenta personal (Gmail u otro proveedor OIDC) que se vincula a su cédula.	Sin cuentas que administrar.	Requiere validar la identidad antes de vincular (D-13).

Fuente: elaboración propia.

5.6 Modelo de autorización RBAC + ABAC

Toda decisión sobre una ruta protegida cruza dos ejes: qué función ejerce el usuario (RBAC) y en qué ámbito la ejerce (ABAC). Los atributos provienen del esquema extendido MINEDEC_Perfil de Workspace (21 atributos: 5 estándar de Google y 16 de negocio) y de las asignaciones que registra cada administrador de aplicativo en AlloyDB [2].

Tabla 5. Dimensiones del modelo de autorización

Eje	Atributos	Uso en la decisión
RBAC	tipoUsuario, subtipoUsuario, cargoFuncion y roles por aplicación	Define qué funciones y permisos atómicos tiene el usuario en cada aplicación.
ABAC por cartera	viceministerio (EDUCACION, DEPORTE, CULTURA)	Separa las aplicaciones y módulos de cada cartera.
ABAC académico	gradoCurso, nivelAcademico	Resuelve el acceso de los estudiantes sin filas de asignación individuales.
ABAC institucional	codigoInstitucion (AMIE), docenteMultisede y sedes asignadas	Acota los datos al plantel o a los planteles del docente.

ABAC territorial y administrativo	zonaDistritoCircuito, codigoDependenciaAdmin	Da alcance de zona, distrito, circuito o dependencia.
ABAC de vigencia	fechaInicioVigencia, fechaFinVigencia, suspended	Deniega fuera de la ventana de vigencia o con la cuenta suspendida.

Fuente: elaboración propia.

Antes de evaluar, el PDP normaliza la ruta solicitada y rechaza las rutas ambiguas (doble codificación, bytes nulos o recorrido fuera de la raíz). Luego busca la regla más específica del catálogo de rutas (exacta, prefijo más largo, extensión y regla por defecto de la aplicación: pública, autenticada o protegida) y, si la ruta es protegida, evalúa el cruce RBAC + ABAC. Los grupos lógicos permiten asignar roles por expresión de atributos, sin asignaciones manuales por persona.

5.7 Contrato de autorización

Las aplicaciones del patrón 1 y el PEP del patrón 2 consumen el mismo contrato REST del SSO, publicado en OpenAPI. Ningún consumidor lo invoca de forma anónima.

5.7.1 Autenticación del consumidor: POST /api/v1/oauth/token

Cada aplicación recibe un client_id y un client_secret que la consola muestra una sola vez y que AlloyDB guarda solo como hash SHA-256, con rotación por ventana de gracia; el PEP usa una credencial de plataforma. El endpoint aplica OAuth 2.0 client credentials [10] y devuelve un token JWT firmado por el SSO con vigencia de 3600 s.

5.7.2 Evaluación: POST /api/v1/authorize

La Tabla 6 describe la solicitud y la Tabla 7, la respuesta. Tanto el permiso como la denegación por política responden 200; el campo autorizado indica la decisión y codigo_decision, el motivo (Tabla 8).

Tabla 6. Campos de la solicitud a /api/v1/authorize

Campo	Obligatorio	Descripción
email_autenticado	Sí	Correo validado en el ID Token o en la aserción SAML.
uuid_aplicacion	Patrón 1	Aplicación que consulta; debe coincidir con la del token del consumidor.
host_solicitado	Patrón 2	Host publicado; el SSO resuelve la aplicación registrada.
ruta_solicitada y metodo_http	Sí	Ruta y método HTTP a evaluar contra el catálogo de rutas.
atributos_contexto	No	IP de origen, user agent, dispositivo gestionado e identificador de la petición.

Fuente: elaboración propia.

Tabla 7. Campos de la respuesta de /api/v1/authorize

Campo	Descripción
autorizado y codigo_decision	Decisión y motivo.
numero_identificacion y	Cédula, pasaporte o código MINEDEC de la persona.

tipo_identificacion	
roles y permisos	Roles y permisos atómicos vigentes en la aplicación.
contexto_territorial	AMIE titular y asignados, nivel y código de jurisdicción, zona y distrito.
assertion_jwt	Aserción firmada con RS256 (aud = aplicación, vigencia de 60 s) que el backend puede verificar con el JWKS del SSO.
politicas_evaluadas, cache_ttl_segundos y timestamp	Trazabilidad de la decisión y tiempo máximo de reutilización (300 s).

Fuente: elaboración propia.

Tabla 8. Códigos de decisión

Código	autorizado	Significado
AUTHZ_PERMITTED	true	El usuario cumple los roles, permisos y condiciones de la ruta.
AUTHZ_PUBLIC_ROUTE	true	La ruta es pública en el catálogo.
AUTHZ_AUTHENTICATED_ROUTE	true	La ruta solo exige una sesión válida de un usuario activo.
AUTHZ_DENIED_POLICY	false	Falta el rol, el permiso o la condición ABAC.
AUTHZ_USER_SUSPENDED	false	La cuenta está suspendida o la persona desvinculada.
AUTHZ_OUTSIDE_VALIDITY_WINDOW	false	Los roles existen pero están fuera de su vigencia.

Fuente: elaboración propia.

5.7.3 Códigos HTTP y cierre ante fallas

Tabla 9. Códigos HTTP del contrato y comportamiento del consumidor

Código	Escenario	Comportamiento del consumidor
200	Evaluación completada.	Permite si autorizado es true; si es false, responde 403 al usuario.
400	Campos faltantes, formato inválido o ruta ambigua.	Rechaza la petición y registra el intento.
401	Token del consumidor ausente, inválido o vencido.	Renueva el token y reintenta una vez; si persiste, deniega.
403	La credencial de una aplicación consulta por otra.	Deniega y genera un evento de seguridad.
404	Aplicación inexistente, no publicada o suspendida.	Deniega.
503 / 500 /	El SSO o sus datos no disponibles, o	Cierre ante fallas: deniega (el PEP

tiempo agotado	error interno.	responde 503). Nunca concede por defecto.

Fuente: elaboración propia.

El SSO publica en /api/v1/.well-known/jwks.json las llaves públicas con las que firma sus tokens y la aserción X-Minedec-Assertion; las llaves privadas se custodian en Secret Manager y se rotan sin interrupción.

5.8 Patrones de integración y paquete estándar

El SSO gobierna aplicaciones con dos patrones que comparten el motor y el contrato (Tabla 10).

Tabla 10. Patrones de integración

Criterio	Patrón 1: integración nativa	Patrón 2: integración perimetral
Aplicaciones	Las dos de C2.3 y las nuevas o con código accesible.	Legadas, cajas negras o en transición (resto del parque).
Autenticación	La aplicación usa OIDC o SAML con Google mediante el paquete estándar.	El PEP autentica antes de que la petición llegue a la aplicación.
Autorización	El backend consulta /api/v1/authorize con uuid_aplicacion.	El PEP consulta /api/v1/authorize con host_solicitado.
Cambios en la aplicación	Inicio y cierre de sesión, control de acceso y vinculación de cuentas.	Nivel protegida: ninguno. Nivel integrada: leer las cabeceras X-Minedec-* y retirar el inicio de sesión local.
Identidad en la aplicación	Respuesta del contrato.	Cabeceras inyectadas, verificables con X-Minedec-Assertion.

Fuente: elaboración propia.

El paquete estándar que entrega C2.2 para el patrón 1 contiene:

1. **Módulo de integración de referencia:** flujo Authorization Code con PKCE S256, SAML 2.0 iniciado por el SP, obtención y renovación del token del consumidor y cliente de /api/v1/authorize con caché breve y cierre ante fallas.
2. **Perfiles OIDC y SAML 2.0 del MINEDEC:** parámetros de configuración para librerías estándar de cualquier lenguaje.
3. **Especificación OpenAPI del contrato.**
4. **Guía de custodia de secretos y certificados** en Secret Manager.
5. **Suite de pruebas de conformidad:** 8 casos obligatorios antes de pasar a producción (autenticación válida y alterada, permiso, denegación, cierre ante fallas, revocación, rotación y anti-suplantación de cabeceras).
6. **Guía de integración** para que el equipo del MINEDEC incorpore aplicaciones de forma autónoma.

5.9 Integración perimetral: alternativas de PEP

El PEP intercepta el tráfico de las aplicaciones del patrón 2, valida la sesión con Google, consulta el PDP y reenvía la petición al backend por un balanceador interno con NEG híbrido [21]. La alternativa basada solo en IAP se descartó porque IAP no puede consultar al SSO [2]. Las Figuras

2 y 3 muestran las dos alternativas viables y la Tabla 11 las compara; la aprobación corresponde al MINEDEC (D-16).

Figura 2. Alternativa 1: Apigee X como PEP

Por definir (TBD): insertar el diagrama de la página «Solución – Alt. 1 Apigee» de Arquitectura_componentes_v2.drawio.

Figura 3. Alternativa 2: GKE Gateway con Envoy como PEP

Por definir (TBD): insertar el diagrama de la página «Solución – Alt. 2 GKE Gateway» de Arquitectura_componentes_v2.drawio.

- **Alternativa 1, Apigee X (recomendada):** encadena políticas declarativas: VerifyJWT, LookupCache, ServiceCallout al PDP, PopulateCache y AssignMessage, que limpia e inyecta las cabeceras [17].
- **Alternativa 2, GKE Gateway con Envoy:** usa Gateway API en GKE Autopilot y el filtro ext_authz de Envoy, que delega cada decisión en el PDP; si el PDP permite, Envoy inyecta las cabeceras; si deniega, bloquea en el borde [18][19].

Tabla 11. Comparación de las alternativas de PEP

Criterio	Alt. 1: Apigee X	Alt. 2: GKE Gateway + Envoy
Gobierno de APIs	Alto: consola, cuotas y analítica integradas.	Medio: manifiestos de Kubernetes y GitOps.
Caché de decisiones en el borde	Nativa (LookupCache / PopulateCache).	Requiere caché externa o consulta en cada petición.
Cloud Armor (WAF y DDoS)	Sí, en el balanceador externo.	Sí, en el Gateway.
Latencia añadida	Baja.	Muy baja.
Curva operativa	Baja a media.	Alta (Kubernetes y Envoy).
Automatización de la publicación	API completa de proxies y entornos.	Recursos declarativos (HTTPRoute, políticas).
Costo	Suscripción o pago por uso de Apigee.	Cómputo del clúster existente.
Dictamen	Recomendada por gobierno y velocidad de adopción.	Viable si se prioriza el costo.

Fuente: elaboración propia.

5.9.1 Cabeceras X-Minedec-* y anti-suplantación

El PEP elimina primero cualquier cabecera X-Minedec-* que llegue desde el cliente y luego inyecta las cabeceras oficiales (Tabla 12), solo en ASCII. El backend que valida X-Minedec-Assertion rechaza cabeceras falsificadas aunque alguien eluda el firewall.

Tabla 12. Cabeceras inyectadas por el PEP

Cabecera	Contenido
X-Minedec-Identificacion	Número de identificación de la persona.
X-Minedec-Tipo-Identificacion	CEDULA, PASAPORTE o CODIGO_MINEDEC.

X-Minedec-Email	Correo autenticado.
X-Minedec-Roles	Roles vigentes, separados por coma.
X-Minedec-AMIE y X-Minedec-AMIEs	Institución titular e instituciones asignadas.
X-Minedec-Jurisdiccion, X-Minedec-Zona y X-Minedec-Distrito	Alcance territorial.
X-Minedec-Request-Id	Identificador de trazabilidad de la petición.
X-Minedec-Assertion	JWT RS256 firmado por el SSO (aud = aplicación, vigencia de 60 s).

Fuente: elaboración propia.

5.9.2 Cierre de red en los centros de datos

- **Regla F1:** el firewall de cada aplicación protegida permite HTTP/HTTPS solo desde los rangos de Google Cloud asociados al PEP (subred proxy-only).
- **Regla F2:** se deniega por defecto cualquier otro acceso directo a los puertos web de la aplicación, desde la red interna o desde Internet.

5.10 Consola de administración y publicación de aplicaciones

El superadministrador incorpora, publica, suspende y retira aplicaciones desde la consola, sin acceso a la consola de Google Cloud. La API de administración no tiene permisos de red ni de balanceadores: delega la infraestructura en el publicador, que aplica los cambios con Infrastructure Manager [20], y en el sondeador, que solo lee el estado.

Tabla 13. Funciones de administración

Función	Alcance
Superadministrador (Seguridad Informática)	Registra aplicaciones y su patrón, hosts y backends; define la regla por defecto y las rutas públicas; emite y rota credenciales; publica, suspende y retira; designa administradores de aplicativo.
Administrador de aplicativo	En sus aplicaciones: rutas protegidas, permisos, roles, perfiles, grupos lógicos, reglas ABAC y asignaciones a usuarios.
Auditor	Consulta de la auditoría y de los reportes, sin cambios.

Fuente: elaboración propia.

La publicación sigue estos controles:

1. **Una publicación a la vez:** el publicador toma un bloqueo consultivo en AlloyDB (pg_try_advisory_lock); las demás solicitudes esperan en cola.
2. **Declaración determinista:** genera apps.auto.tfvars.json desde el catálogo y lo guarda en un bucket con versionado.
3. **Vista previa obligatoria y regla anti-destrucción:** si el plan borra o reemplaza recursos de otra aplicación, o fuera de un retiro explícito, aborta y alerta.
4. **Aplicación controlada** con la cuenta sa-infra-manager.
5. **Verificación:** el sondeador confirma certificado activo, DNS y salud del backend antes de habilitar la aplicación.

Tabla 14. Estados de una aplicación

Estado	Significado
BORRADOR	Registrada; se configuran rutas, roles y administradores; no recibe tráfico.
EN_COLA / APROVISIONANDO	Publicación solicitada / en ejecución en Infrastructure Manager.
PENDIENTES_EXTERNOS	Infraestructura lista; faltan pasos externos verificados (DNS, firewall F1/F2 o consola de Workspace, D-19).
PUBLICADA_PILOTO	Operativa para usuarios piloto.
CORTE_REALIZADO	En producción con el SSO.
SUSPENDIDA	El PDP deniega de inmediato y purga la caché, sin destruir la infraestructura.
FALLIDA / DESPUBLICADA	Error con diagnóstico en la consola / retirada por el flujo explícito.

Fuente: elaboración propia.

Las aplicaciones se publican bajo el subdominio apps.<dominio> delegado a Cloud DNS (D-18).

5.11 Sincronización de identidades y cuotas

La Directory API de Google admite por defecto 2.400 solicitudes por minuto (unas 40 por segundo) [4]. Si el SSO la consultara en cada inicio de sesión, un pico de inicio de año escolar (unos 4 millones de accesos, 8 millones de llamadas) necesitaría más de 55 horas de cuota. Por eso la autenticación y la autorización usan la copia sincronizada y no llaman a Google (Tabla 15).

- **Vía 1, eventos en casi tiempo real:** los eventos de auditoría de administración de Workspace llegan por un sink de Cloud Logging a Pub/Sub y a Cloud Tasks, que despacha al sincronizador a 28 solicitudes por segundo (70 % de la cuota). El nombre de la tarea es el identificador del evento, lo que evita reprocesar duplicados. El sincronizador lee la ficha (users.get), hace un upsert idempotente en AlloyDB y purga la caché.
- **Vía 2, carga inicial y conciliación nocturna:** un job de Cloud Run, disparado por Cloud Scheduler, recorre los dominios y unidades organizativas con users.list (500 usuarios por llamada) y guarda el pageToken en AlloyDB en la misma transacción, para retomar sin repetir.
- **Resiliencia:** reintentos con espera exponencial y jitter (hasta 5 intentos) ante 403 de cuota, 429 y 5xx, respetando Retry-After; los mensajes que siguen fallando van a una cola de mensajes fallidos con alerta.
- **Registro en caliente:** si una cuenta recién creada aún no está en AlloyDB, el PDP no llama a Google: registra una ficha provisional con los datos verificados del token y la completa la sincronización segundos después.
- **Mínimo privilegio:** el sincronizador no tiene llave JSON; firma JWT de corta duración en nombre de sa-workspace-reader, cuya delegación de dominio solo tiene el alcance admin.directory.user.readonly (D-20).

Tabla 15. Consumo de cuota de la Directory API por proceso

Proceso	Llamadas a	Tiempo de cuota	Ventana

	Google	estimado	
Inicio de sesión y autorización con consulta a Google (descartado)	~8.000.000	> 55 horas	Inviable
Inicio de sesión y autorización con el SSO (adoptado)	0	0	Siempre disponible
Conciliación de funcionarios (~170.000)	~340 páginas users.list	< 1 minuto	Nocturna
Conciliación completa (~2,3 millones)	~4.600 páginas users.list	~4 minutos	Nocturna
Cambios diarios (1 % del personal)	~1.700 users.get	Despreciable	Continua
Carga masiva de matrícula (1 millón)	~2.000 páginas users.list	~2 minutos	Planificada

Fuente: elaboración propia.

5.12 Infraestructura en Google Cloud

La plataforma se despliega en un proyecto dedicado, en la región que defina la política de residencia (D-10). Toda la infraestructura (red, GKE, AlloyDB, Redis, Cloud Run, colas, monitoreo e IAM) se define en Terraform y se aplica con Cloud Build; los manifiestos de Kubernetes se despliegan desde el pipeline, no desde equipos locales.

Tabla 16. APIs de Google Cloud de la solución

API	Identificador	Uso
Kubernetes Engine	container.googleapis.com	Clúster GKE Autopilot del PDP, PAP, consola y servicio de identidades.
AlloyDB	alloydb.googleapis.com	Repositorio de identidades, permisos y auditoría.
Memorystore for Redis	redis.googleapis.com	Caché de decisiones y fichas.
Cloud Run	run.googleapis.com	Sincronizador, conciliación, publicador y sondeador.
Cloud Tasks / Pub/Sub / Cloud Scheduler	cloudtasks / pubsub / cloudscheduler.googleapis.com	Ritmo de la sincronización, bus de eventos y disparo nocturno.
Admin SDK	admin.googleapis.com	Lectura del directorio (solo lectura).
Secret Manager	secretmanager.googleapis.com	Llaves de firma, credenciales y secretos.
Identity-Aware Proxy / Cloud Armor	iap / compute.googleapis.com	Protección de la consola y WAF.
Infrastructure Manager	config.googleapis.com	Publicación de aplicaciones con Terraform.
Apigee o Network Services	apigee / networkservices.googleapis.com	PEP del patrón 2 (según D-16).
Cloud Logging /	logging / monitoring /	Auditoría, métricas, alertas y trazas.

Monitoring / Trace	cloudtrace.googleapis.com	

Fuente: elaboración propia.

5.12.1 Red

Tabla 17. Subredes y rangos de referencia

Subred / rango	Propósito	Controles
subnet-gke (/22) con rangos secundarios de pods (/18) y servicios (/20)	Clúster privado de GKE Autopilot.	Nodos sin IP pública; Private Google Access; salida por Cloud NAT donde aplique.
Egress directo a la VPC de Cloud Run (/28)	Sincronizador, conciliación, publicador y sondeador.	Acceso por IP privada a AlloyDB y Redis; ingress interno.
subnet-proxy-only (/23)	Balanceadores internos del PEP hacia los NEG híbridos.	Origen predecible para las reglas F1/F2.
Private Services Access (/20)	AlloyDB y Memorystore.	Sin IP pública.

Fuente: elaboración propia.

- **Conectividad híbrida:** HA VPN con BGP (SLA de 99,99 %) hacia los centros de datos del MINEDEC, con opción de Cloud Interconnect para tráfico alto; la ubicación de las aplicaciones y el operador de enlaces se definen con D-17.
- **Borde:** la consola y la API de administración se publican solo detrás de un balanceador externo con IAP y Cloud Armor (reglas OWASP CRS y límite de tasa); el PDP solo es accesible por red privada [22][23].
- **TLS:** política SSL moderna o restringida con TLS 1.2 como mínimo.

5.12.2 Cuentas de servicio

Tabla 18. Cuentas de servicio y permisos

Cuenta	Usada por	Permisos principales	Restricción
sa-conecta	Pods del PDP, PAP y servicio de identidades (Workload Identity)	Cliente de AlloyDB, Redis, publicador de Pub/Sub, lector de sus secretos, ejecutor del job publicador	Sin permisos de red, balanceadores ni Admin SDK.
sa-gke-nodes	Nodos de GKE Autopilot	Lector de Artifact Registry	Solo imágenes firmadas y escaneadas.
sa-sync / sa-sync-job	Sincronizador / conciliación	Cliente de AlloyDB, Redis, encolador de Cloud Tasks, signJwt sobre sa-workspace-reader	Sin llave JSON.
sa-workspace-reader	Delegación de dominio	Solo admin.directory.user.readonly	Sin roles en GCP; creación de llaves bloqueada por política.

sa-tasks-invoker, sa-pubsub-push, sa-scheduler	Cloud Tasks, Pub/Sub, Cloud Scheduler	Invocador del servicio o job que les corresponde	Nadie más puede invocar esos endpoints.
sa-publicador / sa-infra-manager	Job publicador / Infrastructure Manager	Rol propio publicador_infra, bucket de blueprints, cliente de AlloyDB	Solo cambia infraestructura por Infrastructure Manager tras la vista previa.
sa-catalogo	Sondeador del catálogo	Tres roles propios de solo lectura (balanceadores, certificados, Apigee)	No puede modificar nada.

Fuente: elaboración propia.

5.12.3 Alta disponibilidad y recuperación

- GKE Autopilot regional con escalado horizontal; AlloyDB con instancia primaria de alta disponibilidad, respaldos continuos y recuperación a un punto en el tiempo; Redis con réplica.
- Si Redis falla, el PDP consulta AlloyDB; si ambos fallan, aplica cierre ante fallas.
- Protección contra borrado (deletion_protection) en AlloyDB, el bucket de blueprints y el almacenamiento de auditoría.
- Los objetivos de disponibilidad, RTO y RPO se fijan con D-06 y se prueban en el Documento de Pruebas de Carga y Estrés (C2-52).

5.13 Seguridad, auditoría y observabilidad

- **Auditoría inmutable:** los eventos de autenticación de Workspace y las decisiones y cambios de administración del SSO se registran en Cloud Logging y se exportan a BigQuery con retención bloqueada (WORM); el rol de la aplicación no puede modificar ni borrar la tabla de auditoría. La retención se confirma con el MINEDEC.
- **Reportes:** accesos exitosos y fallidos, suspensiones, cambios de configuración y de permisos, y estado de la sincronización, consultables desde la consola.
- **Logs estructurados:** pino en JSON hacia la salida estándar, con los niveles de Cloud Logging, ocultamiento de secretos y datos personales, y el identificador de traza.
- **Trazas distribuidas:** OpenTelemetry con envío a Cloud Trace; X-Minedec-Request-Id correlaciona la petición del usuario con la decisión del PDP [26].
- **Métricas y alertas:** latencia y errores del PDP, tasa de denegación, profundidad de las colas y de la cola de mensajes fallidos, retraso de la sincronización, salud de AlloyDB y Redis y vencimiento de certificados.
- **Desarrollo seguro:** análisis estático, de dependencias y de imágenes en el pipeline; validación de entradas con esquemas; consultas parametrizadas; endurecimiento de contenedores; secretos solo en Secret Manager.
- **Protección de datos personales:** minimización de datos en logs y tokens, conforme a la LOPDP [28] y a la política de residencia (D-10).

5.14 Decisiones de arquitectura

La Tabla 19 resume las decisiones tomadas y su justificación.

Tabla 19. Decisiones de arquitectura

ID	Decisión	Justificación	Origen
DA-01	Cloud Identity como única fuente de identidades; sin Active Directory.	Directorio existente de las tres poblaciones, con 2SV nativo.	Reunión 22-sep [3]
DA-02	Plataforma de permisos a medida dentro del SSO.	Modelo flexible por atributos, sin replicar el esquema usuario-sede-aplicación-rol.	D-04 resuelta [2]
DA-03	Solo lectura sobre Workspace y copia sincronizada.	Saca a Google del camino crítico y protege la cuota.	RF-GI-05 [2]
DA-04	OIDC con PKCE como protocolo principal y SAML 2.0 como alternativo.	Estándar actual y soporte amplio por stack.	RF-AUT-02 [2]
DA-05	Roles e identificación fuera de la aserción; los devuelve /api/v1/authorize.	Cambios de permisos efectivos sin nuevo inicio de sesión.	RF-AUZ-13 [2]
DA-06	Cierre de sesión por revalidación de 300 s.	Google no implementa SLO.	RF-AUT-06 [2]
DA-07	GKE Autopilot para los servicios en línea y Cloud Run para sincronización y publicación.	Latencia y escalado estables para el PDP; ejecución por eventos y lotes largos para los procesos asíncronos.	Este documento
DA-08	Ámbito por atributos, sin modelar «sede».	Estructura organizacional del Ministerio fusionado.	D-05 resuelta [2]
DA-09	Publicación desde la consola con Infrastructure Manager.	Sin acceso manual a Google Cloud y con control anti-destrucción.	RF-ADM-08 [2]
DA-10	Apigee X recomendado como PEP; GKE Gateway con Envoy como alternativa; IAP solo descartado.	Gobierno y velocidad de adopción; IAP no consulta al PDP.	D-16 pendiente [2]

Fuente: elaboración propia.

6. Validación, criterios de aceptación y evidencias

La Tabla 20 verifica que el documento cubre lo que exige el TDR para el diseño de la arquitectura de C2.2 [1].

Tabla 20. Criterios de aceptación del documento

N.º	Criterio (TDR)	Evidencia	Estado / observación
1	Arquitectura de autenticación centralizada basada en Google Cloud Identity	Secciones 5.3 y 5.4, Figura 1	Cumple; pendiente insertar la Figura 1.
2	Federación SAML 2.0 y OIDC con componentes SP/RP reutilizables	Secciones 5.4.2 y 5.8	Cumple.
3	MFA, políticas de sesión y recuperación de contraseña	Sección 5.4.3	Cumple; la política de 2SV por población la aprueba el MINEDEC.

4	Gestión de sesiones y aplicabilidad de SLO	Sección 5.4.4	Cumple; alcance por aplicación con D-11.
5	Usuarios internos y externos: atributos, perfiles y roles	Secciones 5.4.1, 5.5 y 5.6	Parcial: mecanismo de externos con D-02.
6	Sincronización de directorios	Sección 5.11	Cumple; con datos reales tras D-20.
7	Consola de administración de aplicaciones federadas	Sección 5.10	Cumple.
8	Auditoría, trazabilidad, monitoreo y reportes de accesos	Sección 5.13	Cumple.
9	Alta disponibilidad y recuperación	Sección 5.12.3	Cumple en diseño; objetivos con D-06.
10	Capacidades actuales y proyección de crecimiento	Secciones 5.2 y 5.11	Cumple.
11	Integración y entrega continua e infraestructura como código	Sección 5.12	Cumple.

Fuente: elaboración propia.

Las pruebas funcionales, de seguridad y de carga que validan esta arquitectura se documentan en el Documento de Aceptación Funcional (C2-51) y en el Documento de Pruebas de Carga y Estrés (C2-52).

7. Conclusiones

- El SSO centraliza la autorización de todas las aplicaciones del Ministerio sobre la identidad de Google Cloud Identity, con roles y atributos administrados por el propio Ministerio.
- Al trabajar con una copia sincronizada en AlloyDB y Redis, la autenticación y la autorización no consumen cuota de Google y soportan los picos del año escolar.
- El modelo RBAC + ABAC resuelve a los 2,1 millones de estudiantes por atributos, sin millones de asignaciones individuales.
- Los dos patrones de integración y el paquete estándar permiten incorporar el parque de unas 170 aplicaciones sin desarrollos a medida por lenguaje.
- La publicación desde la consola, la infraestructura como código y la auditoría inmutable permiten operar la plataforma con trazabilidad y sin cambios manuales.

8. Recomendaciones y próximos pasos

8.1 Decisiones pendientes

La Tabla 21 resume las decisiones del MINEDEC que condicionan este diseño [2].

Tabla 21. Decisiones pendientes que condicionan C2.2

Código	Decisión	Impacto en C2.2	¿Bloquea?
D-21	Dominios y tenants de Google Workspace	Federación, proyecto de GCP y sincronización.	Sí, urgente
D-15	Cuentas de prueba por tipo de	Pruebas de inicio de sesión,	Sí, urgente

	usuario	2SV y sincronización.	
D-20	Accesos de lectura para la sincronización	Sincronización con datos reales y carga inicial.	Sí, urgente
D-10	Residencia y tratamiento de datos personales	Región de los proyectos de GCP.	Antes de crear los proyectos
D-16	Alternativa de PEP y su costo	Construcción del patrón 2.	Sí: patrón 2
D-17	Ubicación de las aplicaciones y conectividad híbrida	Enlace con los centros de datos.	Sí: aplicaciones en los centros de datos
D-02	Mecanismo de identidad para usuarios externos y su costo	Flujo de usuarios externos.	Solo ese flujo
D-06	Niveles de servicio y concurrencia pico	Dimensionamiento y pruebas de carga.	No el inicio
D-11	Aplicaciones con cierre de sesión coordinado	Alcance del cierre de sesión.	No
D-12	Inventario de aplicaciones, roles, perfiles y atributos	Catálogo de tipos de usuario y permisos.	No el inicio
D-18 / D-19	Subdominio de publicación y responsables de los pasos externos	Publicación de aplicaciones.	No el inicio

Fuente: elaboración propia.

8.2 Próximos pasos

1. Resolver con el MINEDEC las decisiones urgentes D-21, D-15 y D-20.
2. Insertar las Figuras 1 a 3 desde el archivo draw.io de la arquitectura.
3. Completar en Terraform los módulos de red y de GKE Autopilot y desplegar la plataforma en el ambiente de desarrollo.
4. Ejecutar la sincronización con la unidad organizativa de pruebas y validar los tiempos de revocación.
5. Ejecutar las pruebas de carga con los niveles de servicio que defina el MINEDEC (D-06).

9. Referencias

Tabla 22. Referencias

N.º	Autor / entidad	Documento o recurso	Versión / enlace
[1]	MINEDEC	Términos de Referencia, Componente C2, Subcomponente 2: Implementación del Sistema de Autenticación Centralizado SSO	Versión 01, diciembre de 2025
[2]	CNT	Documento de Requerimientos del SSO	Versión 0.4. https://docs.google.com/document/d/1MzWrDtiKnlwHe_f4h-Tnwyii7AxhHdz5cWFyszZaGO0
[3]	MINEDEC /	Acta de la reunión del 22 de	Definiciones de identidad y Active

	CNT	septiembre de 2026	Directory
[4]	Google	Directory API: límites y cuotas	https://developers.google.com/admin-sdk/directory/v1/limits
[5]	Google	OpenID Connect	https://developers.google.com/identity/openid-connect/openid-connect
[6]	Google	Configurar una app SAML personalizada	https://support.google.com/a/answer/6087519
[7]	OpenID Foundation	OpenID Connect Core 1.0	https://openid.net/specs/openid-connect-core-1_0.html
[8]	IETF	RFC 7636: Proof Key for Code Exchange	https://www.rfc-editor.org/rfc/rfc7636
[9]	OASIS	Security Assertion Markup Language (SAML) 2.0	https://docs.oasis-open.org/security/saml/v2.0/
[10]	IETF	RFC 6749: The OAuth 2.0 Authorization Framework	https://www.rfc-editor.org/rfc/rfc6749
[11]	NIST	SP 800-207: Zero Trust Architecture	https://csrc.nist.gov/pubs/sp/800/207/final
[12]	OASIS	eXtensible Access Control Markup Language (XACML) 3.0	https://docs.oasis-open.org/xacml/3.0/xacml-3.0-core-spec-os-en.html
[13]	Google Cloud	GKE Autopilot	https://cloud.google.com/kubernetes-engine/docs/concepts/autopilot-overview
[14]	Google Cloud	AlloyDB for PostgreSQL	https://cloud.google.com/alloydb/docs
[15]	Google Cloud	Memorystore for Redis	https://cloud.google.com/memorystore/docs/redis
[16]	Google Cloud	Cloud Tasks	https://cloud.google.com/tasks/docs
[17]	Google Cloud	Apigee	https://cloud.google.com/apigee/docs
[18]	Google Cloud	GKE Gateway API	https://cloud.google.com/kubernetes-engine/docs/concepts/gateway-api
[19]	Envoy Proxy	External Authorization (ext_authz)	https://www.envoyproxy.io/docs/envoy/latest/configuration/http/http_filters/ext_authz_filter
[20]	Google Cloud	Infrastructure Manager	https://cloud.google.com/infrastructure-manager/docs
[21]	Google Cloud	NEG de conectividad híbrida	https://cloud.google.com/load-balancing/docs/negs/hybrid-neg-concepts
[22]	Google Cloud	Cloud Armor	https://cloud.google.com/armor/docs

[23]	Google Cloud	Identity-Aware Proxy	https://cloud.google.com/iap/docs
[24]	CNT	C2-59 Documento de Arquitectura aprobado (C2.3)	https://docs.google.com/document/d/1AZkMvFAFbX9rKGg7WN0kY4tl6zIeDg4U84c0rB38q4c
[25]	Google Cloud	Cloud Run jobs	https://cloud.google.com/run/docs/create-jobs
[26]	OpenTelemetry	Documentación de OpenTelemetry	https://opentelemetry.io/docs/
[27]	Google Cloud	Identity Platform	https://cloud.google.com/identity-platform/docs
[28]	Asamblea Nacional del Ecuador	Ley Orgánica de Protección de Datos Personales	Registro Oficial Suplemento 459, 26 de mayo de 2021

Fuente: elaboración propia.

10. Anexos

Anexo A. Glosario

Tabla 23. Glosario de términos

Término	Definición
ABAC	Control de acceso basado en atributos del usuario y del contexto.
AlloyDB	Base de datos PostgreSQL administrada de Google Cloud; repositorio del SSO.
AMIE	Código que identifica a cada institución educativa del Ecuador.
Cierre ante fallas (fail-close)	Regla por la que, ante una falla del autorizador, se deniega el acceso.
Cloud Identity	Servicio de Google para la gestión de identidades; proveedor de identidad de la solución.
IdP	Proveedor de identidad.
MINEDEC_Perfil	Esquema extendido de Workspace con 21 atributos institucionales.
NEG híbrido	Grupo de endpoints de red que apunta a IP y puertos fuera de Google Cloud.
OIDC	OpenID Connect: capa de identidad sobre OAuth 2.0.
PAP	Punto de administración de políticas: consola y API de administración.
PDP	Punto de decisión de políticas: motor de autorización del SSO.
PEP	Punto de ejecución de políticas: aplicación o proxy que aplica la decisión del PDP.
PIP	Punto de información de políticas: fuente de atributos (AlloyDB, Redis y servicio de identidades).
PKCE	Proof Key for Code Exchange: protección del código de autorización

	(RFC 7636).
RBAC	Control de acceso basado en roles.
SLO	Single Logout: cierre de sesión coordinado entre aplicaciones.
SP / RP	Proveedor de servicio (SAML) / parte que confía (OIDC): la aplicación integrada.
TTL	Tiempo de vida de un dato en caché.
2SV	Verificación en dos pasos de Google (segundo factor).

Fuente: elaboración propia.

Anexo B. Riesgos técnicos

Tabla 24. Riesgos técnicos y mitigaciones

ID	Riesgo	Probabilidad / impacto	Mitigación
R-01	Indisponibilidad del PDP o de sus datos.	Baja / Crítico	GKE regional, AlloyDB HA, Redis con réplica y cierre ante fallas.
R-02	Agotamiento de la cuota de la Directory API.	Media / Alto	Google fuera del camino crítico, Cloud Tasks al 70 % y modo lote.
R-03	Retraso en la revocación tras una baja.	Media / Alto	Eventos de auditoría, purga de caché y TTL máximo de 300 s.
R-04	Retraso de las decisiones urgentes (D-21, D-15, D-20).	Alta / Alto	Desarrollo con datos simulados y escalamiento al administrador del contrato.
R-05	Suplantación de cabeceras X-Minedec-*.	Media / Crítico	Limpieza en el PEP, reglas F1/F2 y verificación de X-Minedec-Assertion.
R-06	Una publicación destruye recursos de otra aplicación.	Baja / Alto	Bloqueo consultivo, vista previa obligatoria y regla anti-destrucción.
R-07	Vencimiento de certificados o llaves.	Baja / Alto	Certificados administrados, rotación con material dual y alertas.

Fuente: elaboración propia.